SFC: Multisig Operations | Security Alliance — Security Checklist

Multisig setup, signer management, transaction verification, key security, and emergency procedures.

Org: _____
Owner: _____
Date: _____

1. Governance & Inventory

- [ ] **Named Multisig Operations Owner**
  Is there a clearly named person or team accountable for multisig operations?
- [ ] **Multisig Registry and Documentation**
  Do you maintain a complete, accurate, and accessible record of all your multisigs, their configurations, and their signers?

Notes: _____

2. Risk Assessment & Management

- [ ] **Multisig Classification and Risk-Based Controls**
  Do you classify your multisigs by risk level and apply security controls proportional to each classification?
- [ ] **Contract-Level Security Controls**
  Have you evaluated contract-level security controls that could limit the impact of a multisig compromise?
- [ ] **Exception Approval Process**
  Do you have a process for approving and tracking exceptions to multisig policies?
- [ ] **Wallet Segregation**
  Do you distribute assets across multiple wallets to limit the impact of a single compromise?

Notes: _____

3. Signer Security & Access Control

- [ ] **Signer Address Verification**
  Do you verify that each signer address on your multisigs belongs to the intended person?
- [ ] **Signer Key Management Standards**
  Do you enforce signer key management standards?
- [ ] **Seed Phrase Backup and Protection**
  Do you securely back up and protect signer seed phrases and recovery materials?
- [ ] **Signer Lifecycle Management**
  Do you have a defined process for adding, removing, and periodically verifying signers?

Notes: _____

3. (cont.)

- [ ] **Signer Training and Assessment**
  Are signers trained and assessed on security practices before they are authorized to sign?
- [ ] **Hardware Wallet Standards**
  Do you define and enforce hardware wallet standards for multisig operations?
- [ ] **Secure Signing Environment**
  Do signers use a secure environment for signing operations?
- [ ] **Signer Diversity**
  Are your signers distributed across roles, entities, and geographies to prevent a single event from compromising quorum?

4. Operational Procedures

- [ ] **Transaction Handling Process**
  Do you have a defined, documented process for how transactions are proposed, verified, and executed?
- [ ] **Transaction Audit Trails**
  Do you keep records of all transaction reviews, approvals, and executions?
- [ ] **Tool and Platform Evaluation**
  Do you vet the tools and platforms used for multisig operations before adoption?
- [ ] **Backup Signing Infrastructure**
  Do you have backup infrastructure in case your primary signing tools are unavailable?

Notes: _____

5. Communication & Coordination

- [ ] **Secure Communication Procedures**
  Do you have secure communication procedures for multisig operations, including standard identity verification?
- [ ] **Emergency Contact List**
  Do you maintain a current emergency contact list for all multisig stakeholders?

Notes: _____

6. Emergency Operations

- [ ] **Emergency Playbooks**
  Do you have step-by-step emergency playbooks?
- [ ] **Signer Reachability and Escalation**
  Can you reach enough signers to meet quorum at any time, including outside business hours?
- [ ] **Multisig Monitoring and Alerts**
  Do you monitor all multisigs for unauthorized or suspicious activity?
- [ ] **Emergency Drills and Improvement**
  Do you regularly rehearse your emergency procedures and track improvements?

Notes: _____

frameworks.securityalliance.org